CONFIDENTIAL SECURITY DOCUMENT

Security Assessment Report

Example System

Source-code / white-box vulnerability audit

Document Type	[FILL: e.g. Static (white-box) source-code security assessment]
Subject System	Example System
Stack	[FILL: e.g. Apache Tomcat; Spring Boot REST; PostgreSQL]
Codebase	[FILL: e.g. N web-apps; mostly compiled bytecode + Maven descriptors]
Assessment Date	1 January 2030
Findings	[FILL: N (n Critical, n High, n Medium, n Low)]
Overall Risk	CRITICAL
Classification	**Confidential — Restricted Distribution**

Distribution: This document contains sensitive security information and must not be shared outside authorised personnel responsible for remediation.

Scope of analysis: [FILL: One or two sentences describing the analysis method, e.g. "a read-only, white-box static analysis of the <module> source tree. No application code or configuration was modified."]

1

1 Table of Contents 1

2 Executive Summary 2
2.1 Overview . . . 2
2.2 Overall Risk Rating . . . 2
2.3 Findings by Severity . . . 2
2.4 Findings by Vulnerability Class . . . 3
2.5 Remediation Roadmap (priorities) . . . 3

3 Scope & Methodology 4
3.1 Subject & Scope . . . 4
3.2 Approach . . . 4
3.3 Severity & Verdict Definitions . . . 4
3.4 Verification Outcome . . . 5
3.5 Endpoint / Reference Convention . . . 5

4 Statistics & Risk Posture 6
4.1 Authentication Requirement . . . 6
4.2 Sink Prevalence (module inventories) . . . 6
4.3 Risk Overview by Class . . . 6

5 Systemic Root Causes 7
5.1 R1 — [FILL: e.g. Raw-String SQL Data-Access Layer] . . . 7
5.2 R2 — [FILL: e.g. No Central Authentication / Authorisation] . . . 7
5.3 R3 — [FILL: e.g. Cleartext Secrets & Web-Root Source/Backup Exposure] . . . 7

6 Exploitation Playbooks 8
6.1 [FILL: Vulnerability Class, e.g. SQL Injection] . . . 8
6.2 [FILL: Vulnerability Class 2] . . . 8

7 Full Findings Catalogue 9
7.1 [FILL: Vulnerability Class] ([FILL: n] findings: Critical [FILL: n]) . . . 9

8 Appendix A — Credential & Secret Locations 11

9 Appendix B — Web-Root Exposed-File Inventory 11

2 Executive Summary

Overview

A white-box static security assessment was conducted against Example System. [FILL: One sentence on the sweep methodology, e.g. "the assessment swept every file for the full OWASP-style vulnerability catalogue, and each Critical/High/Medium finding was adversarially re-verified."]

The assessment identified [FILL: N] **distinct findings**. [FILL: One or two sentences summarising the overall posture and the worst realistic outcome.]

CRITICAL — Key Takeaway

Result — [FILL: one-line verdict, e.g. "the module is critically insecure"].

Headline conclusions:

- [FILL: Headline finding 1]
- [FILL: Headline finding 2]
- [FILL: Headline finding 3]
- [FILL: N of M findings require no authentication.]

Overall Risk Rating

CRITICAL

Findings by Severity

Severity	Count	Meaning
CRITICAL	[FILL: n]	[FILL: e.g. Unauthenticated RCE / SQLi / auth bypass]
HIGH	[FILL: n]	[FILL: e.g. Authenticated RCE/SQLi, stored XSS, IDOR exposing PII]
MEDIUM	[FILL: n]	[FILL: e.g. Reflected XSS, CSRF, missing session hardening]
LOW	[FILL: n]	[FILL: e.g. Hygiene / defence-in-depth gaps]
Total	[FILL: N]	[FILL: n unauthenticated]

Findings by Vulnerability Class

Class	Count	Severities
[FILL: e.g. SQL Injection]	[FILL: n]	[FILL: n Critical, n Medium]
[FILL: e.g. Broken Access Control / IDOR]	[FILL: n]	[FILL: n High]
[FILL: e.g. Sensitive Data Exposure]	[FILL: n]	[FILL: n High, n Medium, n Low]

Remediation Roadmap (priorities)

Priority	Action
P1 — Stop the worst outcome	[FILL: e.g. Remediate any injection sinks reaching the OS/filesystem.]
P2 — Systemic	[FILL: e.g. Parameterise all SQL; add a central auth filter; output-encode for XSS; add CSRF tokens.]
P3 — Process	[FILL: e.g. Externalise + encrypt secrets; rotate exposed credentials; hash passwords correctly.]

3 Scope & Methodology

Subject & Scope

Item	Detail
Module	[FILL: name / repo] — Example System
Server / stack	[FILL: e.g. Apache Tomcat 8.5; Spring Boot REST; Oracle]
Codebase size	[FILL: e.g. N web-apps (compiled .class + application.properties + pom.xml)]
Web context	[FILL: e.g. /<api>]
Assessment type	[FILL: e.g. Read-only, white-box (source) static analysis -- discovery only, no code modified]

Approach

1. **Static surface map.** [FILL: Deterministic inventories of every sink class (SQL execution sites, XSS sinks, upload/file sinks, command/dynamic execution, secrets, exposed source/backup files) to quantify prevalence and partition the work.]
2. **Systematic review.** [FILL: Describe how the codebase was divided and reviewed - e.g. per-module review, or a multi-pass finder + adversarial-verifier process.]
3. **Synthesis.** Findings were de-duplicated by pattern, ranked by severity and exploitability, and compiled into this report.

Severity & Verdict Definitions

Level	Definition
CRITICAL	Unauthenticated RCE, unauthenticated SQLi, or authentication bypass.
HIGH	Authenticated RCE/SQLi, stored XSS, IDOR exposing PII/financial data, upload-to-RCE requiring a session.
MEDIUM	Reflected XSS, CSRF, missing session hardening, sensitive data exposure.
LOW / Info	Hygiene and defence-in-depth gaps.

Verification verdicts: *Confirmed* (evidence holds), *NeedsReview* (could not be fully confirmed statically; treat as probable).

Verification Outcome

Verdict	Count	Note
Confirmed	[FILL: n]	Evidence re-validated against the cited code
NeedsReview	[FILL: n]	Retained, flagged; validate dynamically

Endpoint / Reference Convention

[FILL: Explain any convention used to reference endpoints or source locations throughout this report, e.g. "Endpoints follow /<api>/<path-from-webroot>. Pervasive patterns are collapsed into a single finding with an approximate instance count plus representative file:line examples."]

4 Statistics & Risk Posture

Authentication Requirement

Auth required	Count	Interpretation
None (unauthenticated)	[FILL: n]	Exploitable by anyone who can reach the endpoint
Authenticated	[FILL: n]	Requires a valid (any-role) session
Unknown	[FILL: n]	Reachability depends on deployment / inconsistent guards

Sink Prevalence (module inventories)

These deterministic counts measure how widespread each weakness class is across the codebase. They are prevalence measures, not de-duplicated finding counts.

Inventory	Count
[FILL: e.g. Files calling a raw SQL-execution helper]	[FILL: n files]
[FILL: e.g. Reflected-XSS sink lines]	[FILL: n lines]
[FILL: e.g. File/upload sink files]	[FILL: n files]
[FILL: e.g. Credential-bearing config files]	[FILL: n]

Risk Overview by Class

Class	Exploitability	Impact	Primary consequence
[FILL: e.g. SQL Injection]	[FILL: Trivial]	[FILL: Critical]	[FILL: Full DB read/write; auth bypass via login-path SQLi]
[FILL: e.g. Broken Access Control]	[FILL: Trivial]	[FILL: High]	[FILL: Mass IDOR; modify other users' records]

5 Systemic Root Causes

The findings collapse into a small number of architectural defects. Fixing these classes — rather than individual instances — is the only path to materially reducing risk.

R1 — [FILL: e.g. Raw-String SQL Data-Access Layer]

[FILL: Describe the systemic pattern: what shared component or convention causes many individual findings, and why fixing one instance does not fix the class.]

[FILL: Typical call site - e.g. request parameter concatenated into raw SQL]

```
// minimal illustrative code snippet showing the pattern -- replace with your own, no real
    ↪ secrets/paths
```

R2 — [FILL: e.g. No Central Authentication / Authorisation]

[FILL: Describe the second systemic root cause.]

R3 — [FILL: e.g. Cleartext Secrets & Web-Root Source/Backup Exposure]

[FILL: Describe the third systemic root cause.]

6 Exploitation Playbooks

[FILL: Vulnerability Class, e.g. SQL Injection]

Severity: CRITICAL **Auth:** [FILL: None (incl. login-path)]

Description. [FILL: One sentence describing the sink and how it is reached, referencing the systemic root cause it stems from, e.g. "(Root cause R1)".]

[FILL: PoC - e.g. auth bypass / extraction via injectable parameter]

```
# illustrative request/command only -- replace with your own, no real hostnames/tokens/
    ↪ credentials
```

Representative sink: [FILL: module/path/File.java:NN] **Endpoint:** [FILL: METHOD /path]

Impact. [FILL: One sentence.] **Mitigation.** [FILL: One sentence.]

[FILL: Vulnerability Class 2]

Severity: [FILL: HIGH] **Auth:** [FILL: None]

Description. [FILL: ...]

[FILL: PoC title]

```
... illustrative PoC command/request goes here ...
```

Representative sink: [FILL: module/path/File.java:NN] **Endpoint:** [FILL: METHOD /path]

Impact. [FILL: ...] **Mitigation.** [FILL: ...]

7 Full Findings Catalogue

All findings for this module are catalogued below, grouped by vulnerability class and severity-sorted within each class. Each finding carries a unique ID (F-NNN), a metadata table, and the complete evidence, source-to-sink path, and impact.

Class index

Class	Crit	High	Med	Low	Info	Total
[FILL: Class 1]	[FILL: n]	[FILL: n]	[FILL: n]	[FILL: n]	[FILL: n]	[FILL: n]
[FILL: Class 2]	[FILL: n]	[FILL: n]	[FILL: n]	[FILL: n]	[FILL: n]	[FILL: n]

[FILL: Vulnerability Class] ([FILL: n] findings: Critical [FILL: n])

F-001. [FILL: Short, specific finding title]

Severity	CRITICAL	**Class**	[FILL: Vulnerability Class]
Auth	[FILL: Authenticated / None]	**Verdict**	[FILL: Confirmed]
Module	[FILL: module-name]	**Instances**	[FILL: ~n]
Location	[FILL: path/to/File.ext:NN]	**Endpoint**	[FILL: METHOD /path]

Evidence

[FILL: minimal illustrative code excerpt - no real secrets/paths]

Source→Sink

[FILL: One line: where the untrusted input enters, and the exact call that turns it into a vulnerability.]

Impact

[FILL: One or two sentences: what an attacker can concretely do.]

F-002. [FILL: Second finding title in the same class]

Severity	HIGH	**Class**	[FILL: Vulnerability Class]
Auth	[FILL: Authenticated / None]	**Verdict**	[FILL: Confirmed]
Module	[FILL: module-name]	**Instances**	[FILL: ~n]
Location	[FILL: path/to/File.ext:NN]	**Endpoint**	[FILL: METHOD /path]

Evidence

[FILL: minimal illustrative code excerpt]

Source→Sink

[FILL: ...]

Impact

[FILL: ...]

8 Appendix A — Credential & Secret Locations

Per the rules of engagement, only *locations* should be listed here — never secret values. All listed locations must be rotated.

Location	Contents
[FILL: path/to/config.properties]	[FILL: e.g. Cleartext DB user/password + internal DB host IP]
[FILL: Hardcoded keys in ...]	[FILL: Signing keys / SMTP credentials (where present)]

9 Appendix B — Web-Root Exposed-File Inventory

Type	Count	Risk
[FILL: e.g. Dated source backups]	[FILL: n]	[FILL: Source / old-vulnerable-logic disclosure]
[FILL: e.g. .log files (excl. WEB-INF)]	[FILL: n]	[FILL: Info leak]